

Erstellung und Bereitstellung der Artefakte (Environment Setup)

Um das Angriffsszenario für die spätere forensische Analyse vorzubereiten, wurden die bösartigen Artefakte auf der Angreifer-Plattform generiert, die Opfer-Umgebung realistisch eingerichtet und die Zieldaten auf dem Projektserver strukturiert. Dieses Kapitel dokumentiert die einzelnen Setup-Schritte, die eine authentische Angriffskette ermöglichen.

1. Vorbereitung der Phishing-Artefakte auf Kali Linux

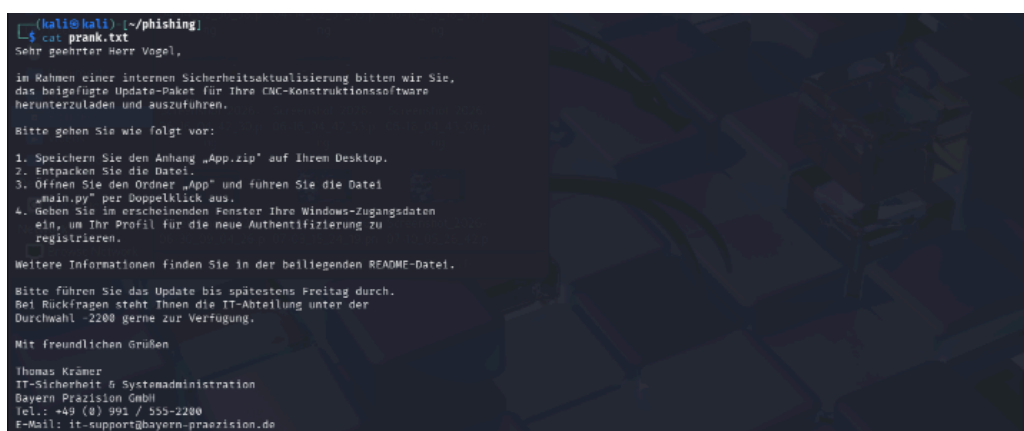
Auf der Angreifer-Plattform (Kali Linux, 192.168.50.10) wurde im Verzeichnis ~/phishing die Schadsoftware vorbereitet und in ein E-Mail-fähiges Format gebracht.

- **Inhalt des App-Ordners:** Der Ordner App enthält die bösartige Quelldatei main.py, die das gefälschte Windows-Sicherheitsfenster generiert, sowie eine begleitende Anleitung namens README.md.
- **Komprimierung:** Der gesamte Ordner wurde als App.zip archiviert, um als E-Mail-Anhang versendet werden zu können.
- **Phishing-Text:** In der Datei prank.txt wurde der deutsche E-Mail-Text vorformuliert, welcher den Benutzer Markus Vogel unter dem Vorwand eines "wichtigen Systemupdates" zur Ausführung verleitet.



```
(kali@kali) ~/phishing
$ cd App
(kali@kali) ~/phishing/App
$ ls
main.py  README.md  Test
```

Figure 1: Übersicht des Phishing-Arbeitsverzeichnisses auf dem Kali-Host



```
(kali@kali) ~/phishing
$ cat prank.txt
Sehr geehrter Herr Vogel,

In Rahmen einer internen Sicherheitsaktualisierung bitten wir Sie,
das beigefügte Update-Paket für Ihre CNC-Konstruktionssoftware
herunterzuladen und auszuführen.

Bitte gehen Sie wie folgt vor:

1. Speichern Sie den Anhang „App.zip“ auf Ihren Desktop.
2. Entpacken Sie die Datei.
3. Öffnen Sie den Ordner „App“ und führen Sie die Datei
   „main.py“ per Doppelklick aus.
4. Geben Sie im erscheinenden Fenster Ihre Windows-Zugangsdaten
   ein, um Ihr Profil für die neue Authentifizierung zu
   registrieren.

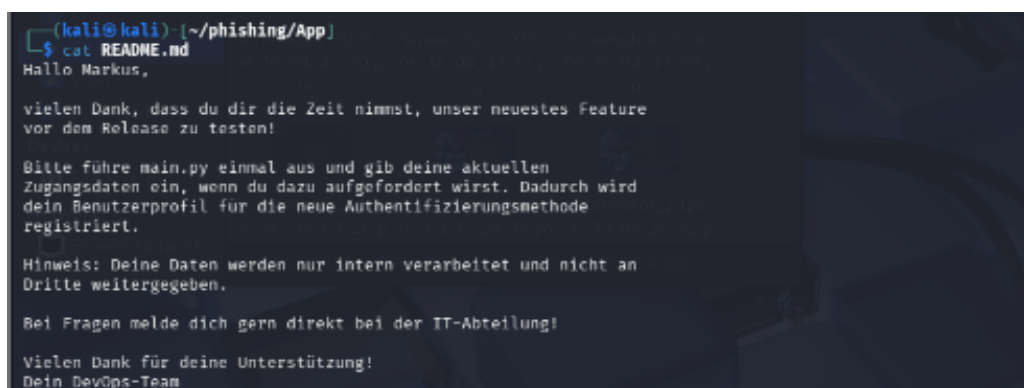
Weitere Informationen finden Sie in der beiliegenden README-Datei.

Bitte führen Sie das Update bis spätestens Freitag durch.
Bei Rückfragen steht Ihnen die IT-Abteilung unter der
Durchwahl -2200 gerne zur Verfügung.

Mit freundlichen Grüßen

Thomas Krämer
IT-Sicherheit & Systemadministration
Bayern Präzision GmbH
Tel.: +49 (0) 991 7 555-2200
E-Mail: it-support@bayern-precision.de
```

Figure 2: Inhalt der Datei prank.txt mit dem vorbereiteten Phishing-Mailtext



```
(kali@kali) ~/phishing/App
$ cat README.md
Hallo Markus,

vielen Dank, dass du dir die Zeit nimmst, unser neuestes Feature
vor dem Release zu testen!

Bitte führe main.py einmal aus und gib deine aktuellen
Zugangsdaten ein, wenn du dazu aufgefordert wirst. Dadurch wird
dein Benutzerprofil für die neue Authentifizierungsmethode
registriert.

Hinweis: Deine Daten werden nur intern verarbeitet und nicht an
Dritte weitergegeben.

Bei Fragen melde dich gern direkt bei der IT-Abteilung!

Vielen Dank für deine Unterstützung!
Dein DevOps-Team
```

Figure 3: Inhalt der README.md innerhalb des präparierten App-Archivs

2. Einrichtung des Windows-Opfer-Clients

Der Windows 10 Client (192.168.50.30, Hostname: DESKTOP-GKDAU52) wurde als Arbeitsplatzsystem des Mitarbeiters Markus Vogel konfiguriert. Um eine realistische Ausgangslage für den Angriff zu simulieren, wurden mehrere Konfigurationsschritte durchgeführt.

2.1 Aktivierung von Remote Desktop (RDP)

Damit der Angreifer nach dem erfolgreichen Diebstahl der Windows-Zugangsdaten per Remote Desktop auf den Client zugreifen kann, wurde der RDP-Dienst auf dem Windows-Client aktiviert.

Konfigurationspfad: **Einstellungen** → **System** → **Remotedesktop** → **Ein**

Nach der Aktivierung wurde der TCP-Port 3389 (ms-wbt-server) auf dem Client für eingehende Verbindungen geöffnet. Diese Einstellung ist entscheidend, da sie den zentralen Angriffsvektor für die Lateral-Movement-Phase darstellt.

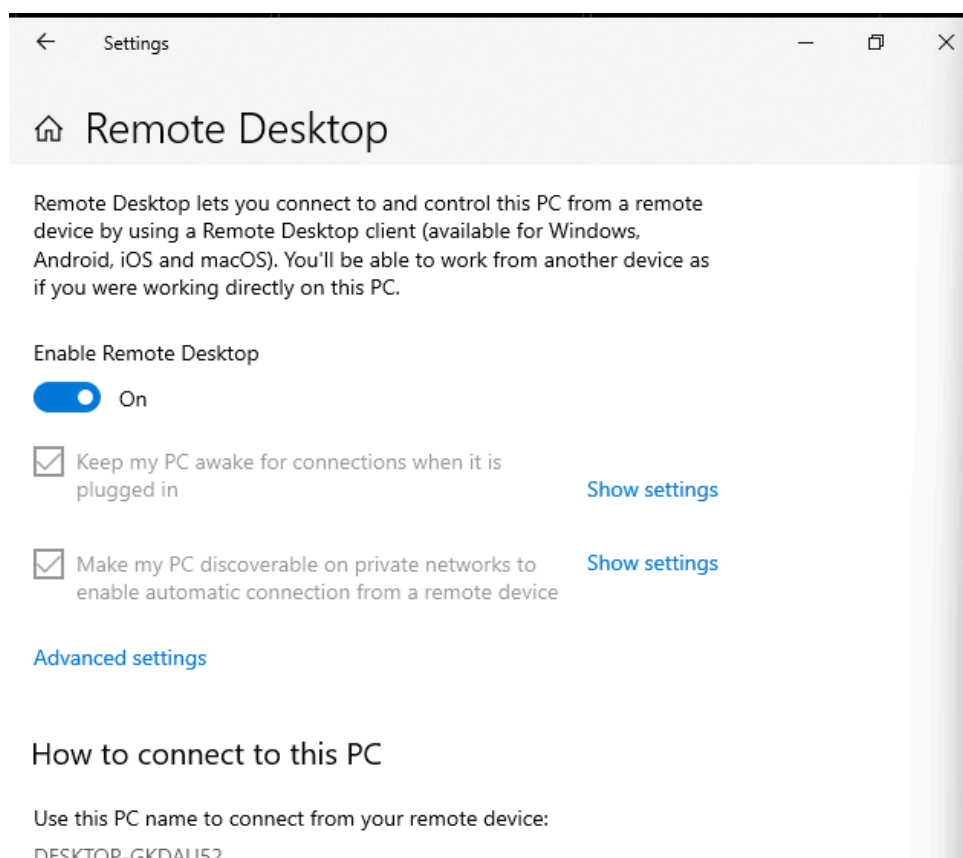


Figure 4: Aktivierung des Remote-Desktop-Dienstes in den Windows-Systemeinstellungen

2.2 Zustellung der Phishing-E-Mail

Das auf Kali erstellte Archiv App.zip wurde als Anhang in eine simulierte E-Mail eingebunden und mittels Mozilla Thunderbird in den lokalen Posteingang (Lokale Ordner) des Opfers m.vogel@bayern-praezision.de zugestellt. Dies simuliert das erfolgreiche Passieren der E-Mail-Filter und stellt sicher, dass die Phishing-Nachricht dem Benutzer in seiner gewohnten Umgebung präsentiert wird.

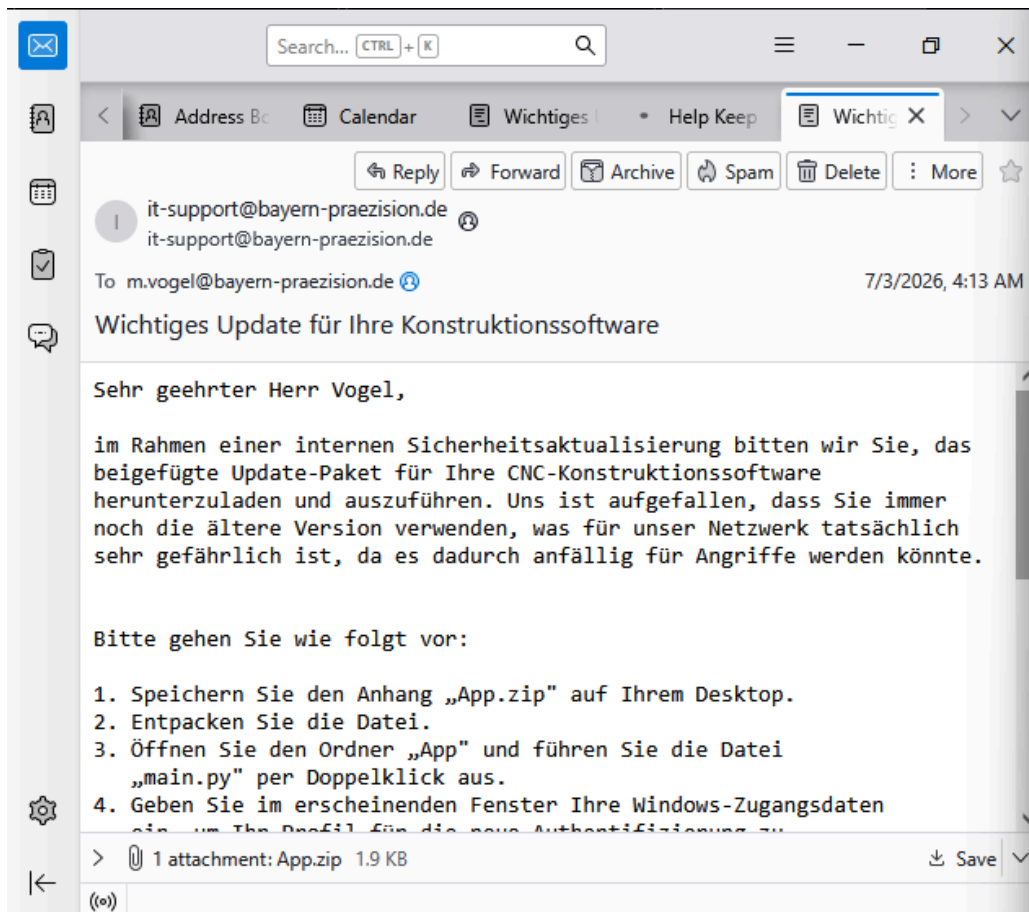


Figure 5: Zugestellte Phishing-E-Mail im lokalen Posteingang von Thunderbird

2.3 Ablage der Klartext-Zugangsdaten

Auf dem Desktop des Opfers wurde eine Datei namens `credentials.txt` angelegt. Diese enthält den leichtfertig notierten Klartext-String `m.vogel:Werkzeug#2026` zusammen mit der IP-Adresse des Projektserver (192.168.50.20). Diese Datei stellt die Brücke zwischen der Kompromittierung des Windows-Clients und dem lateralen Zugriff auf den Linux-Projektserver dar.

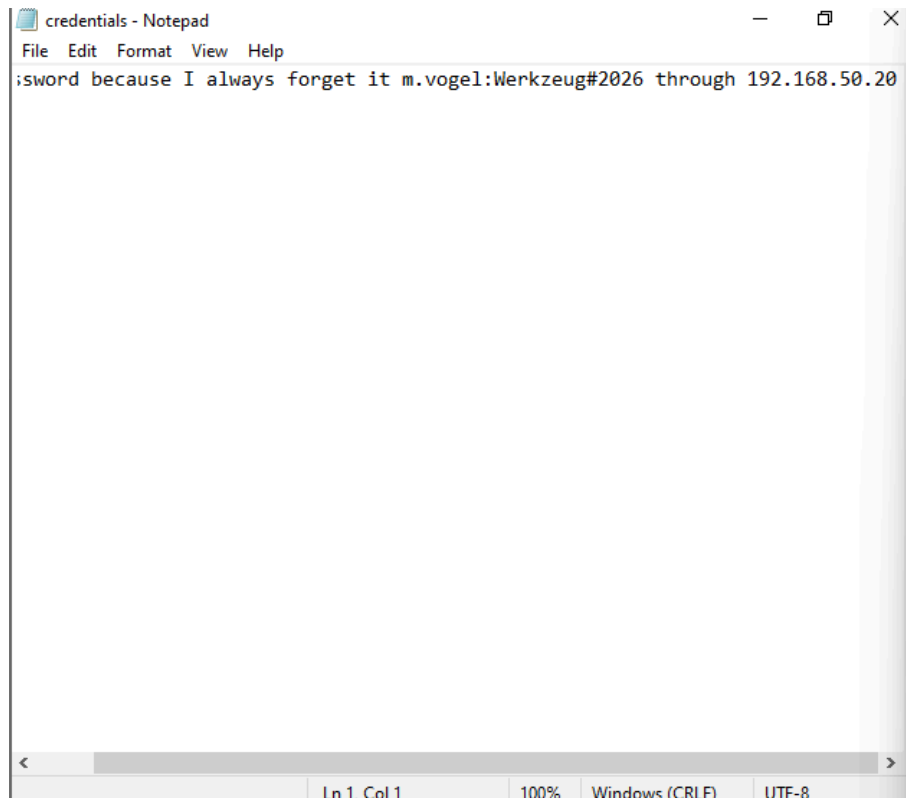


Figure 6: Klartext-Zugangsdaten in der Datei `credentials.txt` auf dem Desktop des Opfers

3. Strukturierung und Berechtigung des Projektserver

Auf dem zentralen Projektserver (Ubuntu Server, 192.168.50.20, angemeldet als `svc@projektserver`) wurden die Zielordner und vertraulichen Dokumente erstellt, die später als Beute des Angriffs exfiltriert werden. Um eine realistische Berechtigungsstruktur zu schaffen, wurden die Besitzrechte explizit auf das Opfer-Konto `m.vogel` übertragen.

3.1 Verzeichnisstruktur anlegen

Die Grundstruktur für die vertraulichen Projektdaten wurde in `/srv/projekte/` mit drei thematischen Unterordnern angelegt:

```
sudo mkdir -p /srv/projekte/{Kunden,Projekte,Verwaltung}
```

3.2 Erstellung der Dummy-Inhalte

Mittels `echo` und `sudo tee` wurden die vertraulichen Beispieldateien erzeugt und mit Platzhalter-Inhalten befüllt, die den sensiblen Charakter der Daten symbolisieren:

```
echo 'CNC-Steuerung v2 - VERTRAULICH' | sudo tee \  
/srv/projekte/Projekte/cnc_steuerung_v2.step
```

```
echo 'Antriebsachse Spezifikation' | sudo tee \  
/srv/projekte/Projekte/antriebsachse.step
```

```
echo 'Kundenliste 2026' | sudo tee \  
/srv/projekte/Kunden/kunden_2026.csv
```

3.3 Anpassung der Besitzrechte (chown)

Damit der Benutzer `m.vogel` nach einer SSH-Anmeldung vollen Lese- und Schreibzugriff auf die Projektdaten hat, wurden die Besitzrechte des gesamten Verzeichnisses rekursiv auf ihn übertragen:

```
sudo chown -R m.vogel:m.vogel /srv/projekte
```

Diese Rechtezuweisung ist essentiell für den späteren Angriffsablauf: Sobald der Angreifer im Besitz der Zugangsdaten von m.vogel ist, kann er die Daten direkt herunterladen und löschen, ohne zusätzliche Rechteauserweiterung durchführen zu müssen.

```
svc@projektserver:~$ sudo mkdir -p /srv/projekte/{Kunden,Projekte,Verwaltung}
svc@projektserver:~$ echo 'CNC-Steuerung v2 -VERTRAULICH' | sudo tee /srv/proj
> ^C
svc@projektserver:~$ echo 'CNC-Steuerung v2 -VERTRAULICH' | sudo tee /srv/pro
CNC-Steuerung v2 -VERTRAULICH
svc@projektserver:~$ echo 'Antriebsachse Spezifikation' | sudo tee /srv/proje
Antriebsachse Spezifikation
svc@projektserver:~$ echo 'Kundenliste 2026' | sudo tee /srv/projekte/Kunden/
Kundenliste 2026
svc@projektserver:~$ sudo chown -R m.vogel:m.vogel /srv/projekte
svc@projektserver:~$ ls -la /srv/projekte/
total 20
drwxr-xr-x 5 m.vogel m.vogel 4096 Jun 30 22:32 .
drwxr-xr-x 3 root    root    4096 Jun 30 22:32 ..
drwxr-xr-x 2 m.vogel m.vogel 4096 Jul  4 21:08 Kunden
drwxr-xr-x 2 m.vogel m.vogel 4096 Jul 10 09:46 Projekte
drwxr-xr-x 2 m.vogel m.vogel 4096 Jan  1  2024 Verwaltung
svc@projektserver:~$
```

Figure 7: Befehlsverlauf auf dem Server: Erstellung der Verzeichnisstruktur, Befüllung der Dummy-Dateien und Rechteübergabe per chown an m.vogel